

Security Assessment Checklist

Thirty controls that stop most real-world breaches. Tick what you already have in place, be honest about what is only "planned", and use the score at the end to decide what to fix first.

How to use it: work through it with the person who runs your IT. One tick = the control is in place, working, and someone would notice if it stopped. Anything else is a blank.

1. IDENTITY & ACCESS 5 items

- ☐ **Multi-factor authentication on every email and admin account**
Stolen passwords are the number one way in. MFA on Microsoft 365 or Google Workspace, VPN, and all admin consoles.
- ☐ **No shared or generic logins**
One person, one account. Shared accounts cannot be traced, disabled or audited when someone leaves.
- ☐ **Leavers are disabled the same day**
A written joiner/mover/leaver step for IT, with HR telling IT before the person's last day.
- ☐ **Admin rights only for the people who need them**
Day-to-day work happens on standard accounts. Separate admin accounts for the few who administer systems.
- ☐ **A password manager and a minimum length of 14 characters**
Long unique passwords per system, generated and stored, instead of one password reused everywhere.

2. ENDPOINTS 4 items

- ☐ **Every laptop and server is patched within 14 days**
Operating system and browser updates applied automatically; critical patches within days, not months.
- ☐ **Endpoint protection with detection and response (EDR) on all devices**
Modern EDR, centrally managed, with alerts that a named person actually reviews.
- ☐ **Laptops and phones are encrypted**
BitLocker, FileVault and device encryption on, so a lost device is an inconvenience rather than a breach.
- ☐ **You know every device that touches company data**
An up-to-date asset list, including personal phones with company email, and the ability to wipe them remotely.

3. EMAIL & PEOPLE 4 items

- ☐ **SPF, DKIM and DMARC are published and DMARC is enforcing**
Stops criminals sending mail as your domain to your customers and suppliers.

- ☐ **Inbound mail is filtered for phishing and malicious attachments**
Links rewritten and scanned, executable attachments blocked, external-sender banners shown.

- ☐ **Staff receive security awareness training at least twice a year**
Short, practical sessions with simulated phishing, and a no-blame way to report a suspicious message.

- ☐ **Payment changes are verified by phone before money moves**
A call to a known number for any new bank details or "urgent" transfer request, no exceptions for the CEO.

4. NETWORK & PERIMETER 4 items

- ☐ **Nothing is exposed to the internet that does not need to be**
No remote desktop, database or admin panels open to the world; an external scan in the last 12 months proves it.

- ☐ **Remote access only through VPN or zero-trust access with MFA**
And the VPN appliance itself is patched, since these are heavily targeted.

- ☐ **Guest and IoT Wi-Fi are separated from the corporate network**
Visitors, printers, cameras and smart TVs cannot reach file servers or staff laptops.

- ☐ **Firewall rules and admin passwords were changed from the defaults and are reviewed yearly**
Vendor defaults are public knowledge. Someone owns the rule set and can explain every open port.

5. CLOUD & SAAS 4 items

- ☐ **Microsoft 365 or Google Workspace security defaults are reviewed and hardened**
Legacy authentication off, conditional access on, mailbox forwarding to external addresses blocked.

- ☐ **Cloud storage sharing is restricted and reviewed**
No "anyone with the link" sharing on company folders; external shares expire.

- ☐ **Cloud infrastructure (Azure, AWS, GCP) has MFA on the root account and no public storage buckets**
Billing alerts are on, so a hijacked account is noticed within a day.

- ☐ **You have a list of every SaaS tool that holds company data**
Including the ones a department signed up for with a credit card, and who owns each account.

6. DATA & BACKUP 4 items

- ☐ **Backups run daily, one copy is offline or immutable, and a restore was tested this quarter**
Ransomware deletes reachable backups first. A backup you have never restored is a hope, not a control.

- ☐ **You know where personal data lives and why you hold it**
A simple data map, which the UAE Personal Data Protection Law expects you to be able to produce.
- ☐ **Sensitive files are restricted to the teams that need them**
HR, finance and legal folders are not readable by everyone in the company.
- ☐ **Old devices and drives are wiped or destroyed before disposal**
With a record of what was disposed of and when.

7. DETECTION & RESPONSE 5 items

- ☐ **Logs from email, identity, firewall and endpoints are kept for at least 90 days**
Without logs, an investigation cannot tell you what was taken.
- ☐ **Someone is alerted when something suspicious happens, including at night**
Impossible-travel logins, mass file changes, new admin accounts, disabled security tools.
- ☐ **A one-page incident response plan exists and has a phone tree**
Who decides, who calls the bank, who calls customers, who calls the regulator, and where the plan lives if email is down.
- ☐ **You have run a tabletop exercise in the last 12 months**
Ninety minutes with leadership walking through a ransomware or business-email-compromise scenario.
- ☐ **An independent penetration test or security assessment was done in the last 12 months**
Findings tracked to closure, not filed. Your own team cannot mark its own homework.

Score yourself

- | | |
|--------------------|---|
| 0–10 ticks | Exposed. A single phishing email or a lost laptop could stop the business. Start with items 1, 6, 7, 9 and 23 this month. |
| 11–20 ticks | Typical for a UAE SME. The basics are there but there are gaps an attacker will find before you do. Prioritise identity, backup and detection. |
| 21–30 ticks | Mature. Your next step is proving it: an independent assessment, and a framework such as ISO 27001 or the UAE IA standard if customers or regulators ask. |

Not sure how to close the gaps?

Underwings offers a free security assessment for UAE organisations: a short call, a review of your answers to this checklist, and a written list of what to fix first. No obligation.

+971 54 707 8203
contact@underwings.org
underwings.org